Design governance with CAF and the Well-Architected Framework



Tim Warner

Principal Author | IT Ops | Pluralsight

TechTrainerTim.com

Checking in with Globomantics



Two new subscriptions appeared outside the process

The AWS footprint grew again, nobody told security

Controls are named but not enforced anywhere

What keeps the design true after we leave the room?

Separate CAF from WAF

Two frameworks, two different questions

CAF	vs.	WAF
Cloud Adoption Framework		Well-Architected Framework
Governs the estate over its lifecycle		Evaluates one workload against pillars
Seven methodologies, org-wide		Five pillars, security is one
Answers: how do we adopt and keep control		Answers: is this workload built well
Scope: the whole cloud estate		Scope: a single workload

The WAF security pillar, in five principles

Plan your security readiness

Design to protect confidentiality

Design to protect integrity

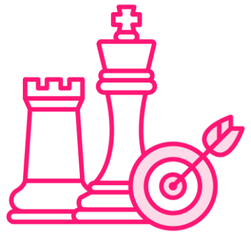
Design to protect availability

Sustain and evolve your security posture

The middle three are the CIA triad

Evaluate an existing governance strategy

Gap analysis runs at three scopes



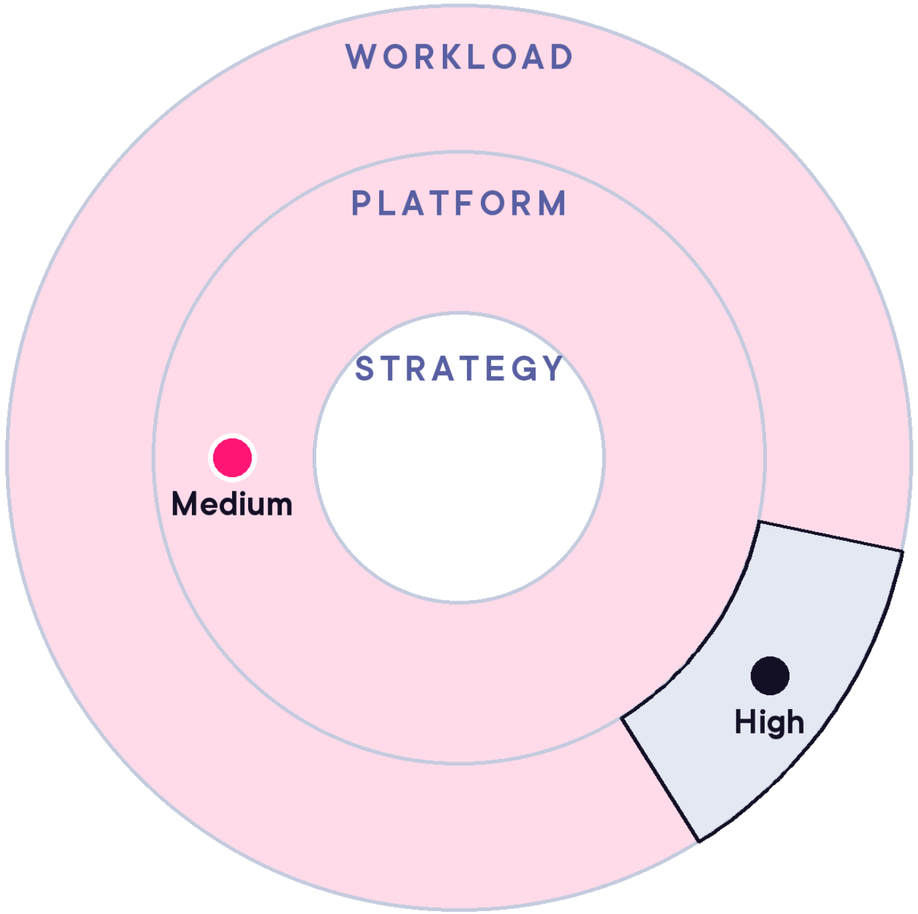
Strategy scope, assessed against CAF



Platform scope, assessed against landing zone controls



Workload scope, assessed against the WAF checklist



Shaded area = what one gap reaches

Medium here beats high there.

Then prioritize by blast radius, not noise

Risk level first, critical and high before the rest

Blast radius: platform gaps outrank single workloads

Compliance obligations can override risk order

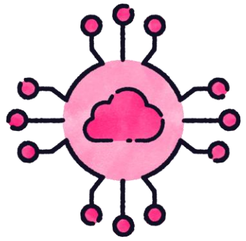
Quick wins where config beats redesign

Govern with Azure landing zones

Microsoft Learn, Understand Azure landing zones

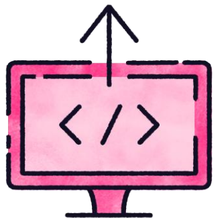
“Think of an Azure landing zone as a prepared runway”

Platform vs. application landing zones



Platform

- Deployed once, shared by everything
- Management groups and subscription organization
- Centralized security, governance, core networking
- Logging, monitoring, operational tooling



Application

- Deployed many times, usually as subscriptions
- Where workloads actually run
- Inherits policy and guardrails from the platform
- Teams move fast without bypassing governance

Define the boundary, or it defines itself

Who owns identity and conditional access

Which network controls are central, which are local

Where telemetry goes, and who triages it

Which policies are non-negotiable platform-wide

Demo: Govern by inheritance, not by goodwill

Show the management group hierarchy, the Deny assignment above it, and a deployment that never happens

Relevant SC-100 practice question

Regulated data keeps landing in ungoverned subscriptions. What do you recommend?

A. run the Well-Architected Review on each affected workload

B. Deny policy at the management group, inherited by every subscription

C. Defender for Cloud recommendations, remediated per subscription

D. A subscription request process with security sign-off

Checking out with Globomantics



CAF governs the estate; WAF evaluates the workload

Evaluate at three scopes and fix at the matching one

Prioritize by blast radius and compliance, not volume

Landing zones make the governed path the default path